Part 1. Security Policy Set

Policy	What it protects	NIST CSF 2.0	Enforced by
Acceptable Use	How staff use accounts, devices, data and the internet	Govern (GV.PO, GV.RR), Protect (PR.AT)	Standard user accounts, no local admin, Defender, event logging
Access Control	Who can reach which system and data	Protect (PR.AA, PR.IR)	AD groups, password and lockout policy, admin tiering, Windows LAPS, share permissions, pfSense zone rules, key-only SSH
Incident Response	How Acme detects, contains and recovers from incidents	Respond (RS.MA, RS.AN, RS.CO, RS.MI), Recover (RC.CP, RC.CO), Detect (DE.AE)	Central log collector in the Mgmt zone, pfSense isolation rules, shadow copies

Part 1.1. Acceptable Use Policy

Purpose: Staff may use Acme's systems for their work, in ways that keep source code, builds, player trust and the network safe. Most incidents start with an ordinary action, such as opening an attachment, so this policy sets the everyday rules.

Scope: All employees, contractors and visitors who use an Acme account, device, network, file share or game server.

Rules:
1. Accounts. Use only your own account and never share passwords. Do daily work with your standard account. IT staff use a separate admin account (for example john.admin) only for admin tasks, and only from the Mgmt zone.
2. Company data. Source code, builds and art stay on company shares and approved tools. Do not copy them to personal devices, personal cloud storage or removable media without written IT approval. Pre-release builds never leave the company.

3. Devices and software. Only Acme-managed devices may join the User, Server or Mgmt networks. Do not install unapproved software, disable Microsoft Defender or bypass security settings. Standard users have no local admin rights.
4. Email and Internet. Internet access is for work, with reasonable personal use. Do not open unexpected attachments or links, even if they look like invoices. Report suspicious messages to IT straight away.
5. Game servers and player data. Staff access player information only when their role requires it. Official game servers are not used for testing without approval from the IT Lead.
6. Monitoring. Activity on company systems is logged for security: logons, programs started, PowerShell use and changes to shared files. Logs are reviewed by authorised IT staff, within applicable law.
7. Reporting. Report a lost device, a suspected compromise or a policy breach to IT immediately. Reports made in good faith are never punished, even when the reporter caused the problem.

Responsibilities:

Role	Responsibility
All staff	Follow this policy; complete annual security and phishing training; report incidents immediately
Department leads	Make sure their team knows the rules; approve exceptions for their data
IT Lead	Maintain the policy, run training, review logs, grant written exceptions
HR	Include the policy in onboarding; handle breaches through the disciplinary process
Studio Director	Approves the policy; reviewed every year or after a major incident

Enforcement: A breach may lead to loss of access and disciplinary action. Exceptions must be written, time-limited and approved by the IT Lead.

NIST CSF 2.0 mapping: Govern: GV.PO (policy is set, communicated and enforced) and GV.RR (roles and responsibilities). Protect: PR.AT (staff awareness and training).

Part 1.2: Access Control Policy

Purpose: Every person and system gets the least access its job needs, granted through groups and network rules that are written down and reviewed. This limits what one stolen account or one compromised machine can damage.

Scope: All Active Directory accounts, workstations, servers, file shares, pfSense firewall, DMZ game servers and every admin interface.

Rules:
1. Identity and passwords. Every person has one named account. Passwords are at least 14 characters, meet complexity rules and cannot reuse the last 24. Accounts lock for 15 minutes after 5 failed logons.
2. Multi-factor authentication (MFA). Required for remote access and admin accounts where the system supports it.
3. Access through groups. Permissions go to groups, never to individual accounts. File share access follows the table below. Users only see shares they can open.
4. Joiners, movers and leavers. The department lead and IT approve every access request. HR tells IT about changes on the day. Leavers are disabled the same day. Access is reviewed every quarter.
5. Privileged access. Admin work uses a separate admin account from a Mgmt-zone workstation only. Domain Admin accounts are blocked from logging on to user workstations. Local administrator passwords are unique per machine and rotated every 30 days by Windows LAPS.
6. Network access. The network is split into four zones (User, Server, Mgmt, DMZ). Traffic between zones is allowed only by an explicit firewall rule; everything else is blocked and logged. The firewall is managed only from the Mgmt zone.
7. Servers in the DMZ. Admin access is by SSH key only, from the Mgmt jump host only. Password and root logons are disabled. The game service runs as an unprivileged, sandboxed account.
8. Logging access. Logons, privileged logons and changes to shared files are forwarded to the log collector in the Mgmt zone. Staff who review logs get read-only access, not admin rights.

File share permissions.

Share	Developers	Artists	Build Engineers
Source	Modify	No access	Modify
Builds	Read	Read	Modify
Art	Read	Modify	Read

Allowed traffic between zones.

From	To	Allowed	Why
User	Server	AD ports and SMB 445 only	Logon, Group Policy, file shares
User, Server	Mgmt	TCP 5985	Event forwarding
Mgmt	Server	RDP 3389 and AD ports	Administration
Mgmt (jump host)	DMZ	SSH 22	Administration
Mgmt	pfSense	HTTPS	Firewall management
Internet	DMZ	UDP 7777 only	Players
DMZ	anywhere	Replies only	A compromised game server cannot pivot forward

Responsibilites:

Role	Accountability
Department leads	Approve access to their data, confirm the quarterly review
IT lead	Approves all privileged access and firewall rule changes
IT administrators	Implement access, run quarterly reviews, keep the zone rules documented

HR	Report joiners, movers and leavers on the day
All staff	Protect their credentials, request only the access they need

NIST CSF 2.0 mapping: Protect: PR.AA (identity management, authentication and access control) and PR.IR (networks protected from unauthorised logical access).

Part 1.3. Incident Response Policy

Purpose: Acme detects, contains and recovers from security incidents quickly, with named roles, preserved evidence and one consistent voice to staff, players and the press. The phases follow NIST SP 800-61 Rev. 3, which aligns incident response with CSF 2.0.

Scope: Any event that threatens the confidentiality, integrity or availability of Acme systems, data or game services. This includes malware, ransomware, account compromise, data theft, denial of service against the game servers and lost devices.

Roles:

Role	Held by	Duties
Incident lead	IT lead	Declares severity, runs the response, approves containment, keeps the decision log
Technical Lead	Senior IT administrator	Analyses logs, isolates systems, preserves evidence, leads recovery
Executive sponsor	Studio Director	Business decisions: shutdowns, spending, ransom, public statements
Communications Lead	Community manager	The only voice to press and players; drafts staff

		messages
Legal Counsel	Retained law firm	Breach-notification duties, law enforcement, ransom legality
HR	HR lead	Staff involved in the incident, under the no-blame rule
Outside Help	Cyber insurer’s incident response firm	Forensics and recovery support for Severity 1

Severity levels:

Severity	Meaning	Who is told, and how fast
3 - low	One user or device; no data affected	IT, same working day
2 - high	Several devices or one department; sensitive data may be affected	Incident Lead and Executive Sponsor within 1 hour
1 - critical	Several departments, domain or backup compromise, confirmed data theft or public impact	Whole response team, legal and insurer immediately; leadership briefed every 4 hours

Rules by phase
1. Detect and analyse. Anyone can report through the help desk. The Technical Lead checks the log collector first: logons (4624/4625), process starts with command lines (4688), PowerShell (4104), file changes on shares (4663), Defender alerts and log clearing (1102).
2. Contain. Isolate rather than power off, so memory evidence survives. Approved actions: block a host or a whole zone at pfSense, block an account's share access, disable accounts, take shares offline. Zone isolation always keeps log forwarding to the

collector open.
3. Preserve evidence. Before changing a system, capture memory and disk images, and export and hash the collector's logs. Record every item in a chain-of-custody log. Only the Incident Lead may authorise deleting or altering evidence.
4. Eradicate and recover. Rebuild compromised systems from known-good media. Reset credentials from a clean Mgmt workstation, including admin accounts, SSH keys and the AD krbtgt ccount (twice) if the domain is compromised. Recovery order: identity (DC01), then shared data, then workstations. Game servers keep running if their isolation is confirmed.
5. Communicate. Staff are told through an out-of-band channel (phone or SMS group) when email or AD may be compromised. Only the Communications Lead speaks publicly, with statements approved by the Executive Sponsor and legal counsel. No statement claims a fact that is not yet verified.
6. Notify. Legal counsel decides on regulator and customer notification within legal deadlines (for example, 72 hours under GDPR if EU players' data is involved). The Incident Lead contacts the insurer and law enforcement after approval from the Executive Sponsor.
7. Ransom. Acme's default is not to pay. Only the Executive Sponsor can decide otherwise, with legal counsel and the insurer, and only after a sanctions check.
8. Learn. An after-action review takes place within two weeks of closing a Severity 1 or 2 incident. This policy is tested with a tabletop exercise every year.

NIST CSF 2.0 mapping. Respond: RS.MA (incident management), RS.AN (analysis), RS.CO (reporting and communication), RS.MI (mitigation). Recover: RC.RP (recovery plan execution), RC.CO (recovery communication). Detect: DE.AE (analysis of adverse events).

Part 2. Ransomware Tabletop: After-action report

Result: The plan contained the attack to the User and Server zones and kept the game online, but it failed to detect the attack over the weekend and had no clean backup once the domain was compromised.

Scenario: A staff member opened an “Invoice” attachment on Friday afternoon. On Monday at 07:40, files on the shared drives end in .locked and a ransom note appears. By Day 2, the attackers have encrypted the backups, leaked customer records and raised the ransom.

Participants (by role): Incident Lead (IT Lead), Technical Lead (senior IT administrator), Executive Sponsor (Studio Director), Communications Lead (community manager), external legal counsel and HR.

Method: Each inject was walked through in order against the network diagram and the Incident Response Policy. Where possible, answers were checked against the lab rather than assumed. For example, the share permissions, the log collector's events and the DMZ's blocked outbound traffic were all tested before the exercise.

Decision timeline

Time	Inject	Severity	Key decision
Mon 07:40	1	3	Help desk opens an incident; Technical Lead assigned
Mon 07:55	1	3	Affected workstation isolated at pfSense, not powered off; memory captured
Mon 08:05	1	3	That account blocked from all three shares
Mon 08:20	2	1	Severity 1 declared; all shares taken offline
Mon 08:25	2	1	User zone isolated at pfSense, log forwarding kept open
Mon 08:40	2	1	Insurer called; outside incident response firm engaged
Mon 09:00	2	1	First infected machine traced

			from Friday's logs; accounts disabled
Mon 09:35	3	1	Domain treated as compromised; Server zone isolated
Mon 10:00	3	1	Holding statement to the reporter; legal counsel and law enforcement told
Day 2	4	1	Leaked sample verified; notifications prepared; decision not to pay

Inject 1:

Question	Decision
Who is notified	Help desk logs the call and alerts the IT Lead (Incident Lead), who assigns the Technical Lead. Studio Director told an incident is open. Severity 3 (one user).
What is contained	07:55: the workstation is cut off by a pfSense block rule on the User interface (or its network adapter disconnected). It stays powered on. 08:05: that account is blocked from the Source, Builds and Art shares on DC01 and its open file sessions are closed.
What evidence is preserved	Ransom note and a sample .locked file; a

	memory and disk snapshot of the workstation. From the collector: 4663 file-change events (these name the account doing the encrypting), 4688 command lines and 4104 PowerShell.
What do we tell people	Staff: do not open the shared drives; report anything unusual. Leadership: one user affected, scope being checked. Customers: nothing yet.
Which policy applies	Incident Response (report, triage, contain). Acceptable Use, rule 7 (prompt reporting).

Inject 2:

Question	Decision
Who is notified?	Severity 1 declared at 08:20. Whole response team, Studio Director, cyber insurer (its incident response firm), legal counsel and HR (the staff member is treated under the no-blame rule).
What is contained?	All shares taken offline. The User zone is isolated at pfSense, except TCP 5985 to the log collector, so evidence keeps flowing. Accounts seen in the 4663 events are disabled. Admin group memberships are reviewed: how did one attacker reach three departments' data?
What evidence is preserved?	Friday's events from the first machine: 4688 command lines and the Defender attack surface reduction (ASR) audit event 1122 that logged but did not block the attack. The email and the

	attachment's hash. Logon events (4624, 4672) showing which accounts were used where.
What do we tell people?	Staff (by phone or SMS): stay off shares, do not reboot or wipe anything, report the same email if received. Leadership: development is paused; impact and likely duration. Customers: nothing yet; nothing is confirmed.
Which policy applies?	Incident Response (escalation, containment, evidence). Access Control (disabling accounts, privileged access review). Acceptable Use, rule 4 (attachments).

Inject 3:

Question	Decision
Who is notified	Legal counsel takes over notification decisions. Law enforcement (for example the FBI's IC3 in the US, or the national cyber-incident centre). The insurer is updated. Regulators are not told yet, but legal starts the clock on notification deadlines.
What is contained	The domain is treated as compromised: the Server zone is isolated, and the collector is checked for log clearing (1102). Admin passwords and SSH keys are reset from a clean Mgmt workstation, and two `krbtgt` resets are planned. The DMZ game servers stay online: they have no path inward or outward.
What evidence is preserved	Memory and disk images of DC01 before any rebuild. The collector's logs, exported

	and hashed; they survived because the collector is in the Mgmt zone, which the User and Server zones can only send logs to.
What do we tell people	Reporter: one statement from the Communications Lead: “We are investigating a security incident and will share verified information as soon as we have it.” No guessing about customer data. Players: game services are running normally. Staff: do not speak to the press. Leadership: no clean backup exists; recovery options and costs.
Which policy applies	Incident Response (communications, evidence, notification). Its recovery section assumed the backups would survive, and they did not.

Inject 4:

Question	Decision
Who is notified	On legal advice: the relevant regulators and the affected customers. Law enforcement and the insurer are updated.
What is contained	The leaked sample is checked to see whether it is genuine and where it came from. Acme's asset inventory lists no customer data inside this network, so two sources are investigated: player data copied to a share or workstation against policy, or a breach of the account system that sits outside this network. Affected players' passwords are reset. pfSense

	logs are searched for large outbound transfers from the User and Server zones.
What evidence is preserved	The leak site page and sample (captured, hashed), all ransom communications, and the pfSense outbound logs.
What do we tell people	Customers: what happened, which data, what Acme is doing and what they should do (change passwords, watch for phishing). Staff: a holding statement and a reminder not to comment publicly. Leadership: the ransom decision.
Ransom decision	Do not pay, under the policy default. Paying cannot undo a leak that has already happened, and there is no guarantee of a working decryptor. Source code is rebuilt from developers' local working copies, builds from source, and art from artists' local files; some recent work is lost.
Which policy applies	Incident Response (notification, communications, ransom rule). Access Control (credential resets).

What worked and what failed

Segmentation and central logging held up. Detection, backups, data inventory did not

What worked:

Control	How it helped	Evidence from the lab
Zone segmentation	The DMZ had no path from	DMZ outbound

	the User or Server zones, so the game stayed online and players were unaffected	connections blocked by both the server's own firewall and pfSense; only UDP 7777 reachable from the Internet
Logs kept off the affected machines	The collector in the Mgmt zone kept the full story from Friday onward, including who changed which files	Forwarded Events from DC01 and the workstation; User and Server zones can reach the collector only on TCP 5985
Least privilege on shares	Limited what one account could encrypt, and turned “three departments affected” into an early warning of privileged compromise	dev.alice cannot write to Art; art.bob cannot even see Source
Admin tiering and windows Laps	Domain Admin credentials were never typed on the first infected workstation; local admin passwords could not be reused across machines	Domain Admin logon to the user workstation refused
Clear roles and severity levels	Escalation to Severity 1 took 5 minutes, with no debate over who decides	Incident Response Policy roles and severity table

What failed

Gap	Effect in the scenario	Root cause
No alerting	Friday's Defender events and Monday's burst of file changes sat unread until an employee called	The collector stores events but nobody is notified; review is manual

Ransomware protection in audit mode	Defender logged the attack on Friday and blocked nothing	ASR and Controlled Folder Access left in Audit mode after testing
Backups on the same server	Once the attacker had admin rights on DC01, the only restore point was gone	Shadow copies live on DC01's own data volume, under domain credentials
File shares on the domain controller	Isolating the Server zone stopped logons and file access together	DC01 does both identity and file serving
Customer data missing from the inventory	Acme could not tell the reporter, regulators or players what data existed or where	The asset inventory covers code, builds and art, not player data
No MFA	A phished password or session was enough to act as the user	MFA is a target in the Access Control Policy, not yet built
Limited outbound visibility	Data theft could not be quickly proven or ruled out	pfSense logs are kept only on pfSense, with short retention

Improvements

#	Improvement	Change to the network or policy	Fixes	NIST CSF 2.0
1	Offline, immutable backups	A backup server in the Mgmt zone, not joined to the domain, with its own credentials. It pulls nightly copies of the shares; a	Backups on the same server	PR.DS (backups protected and tested), RC.RP

		weekly copy goes offline or to immutable storage (3-2-1 rule). pfSense allows only the backup server to reach DC01, and nothing to reach the backup server except Mgmt admins. Restores tested every quarter. Incident Response Policy recovery section updated to match.		
2	Block mode and real alerting	Switch ASR and Controlled Folder Access to Block (one setting in the Workstation Baseline GPO). On the collector, raise alerts for log clearing (1102), Defender detections and ASR hits (1116, 1121, 1122), lockouts (4740) and bursts of file changes (4663). Daily log review added to IT duties.	No alerting; audit mode	DE.CM, DE.AE

3	Separate file server and version control	Move the shares off DC01 to a dedicated file server in the Server zone, so DC01 only handles identity. Move source code into version control (for example Perforce or Git) that keeps full history on the server, out of reach of a user's file access.	File shares on the DC; one account can damage all of Source	PR.IR, PR.DS
4	Customer data in the inventory	Add player data to the asset inventory with its owner and location. Keep it only in the account system's restricted environment, encrypted. Acceptable Use rule 5 is extended: no player data exports to shares or workstations.	Customer data missing from the inventory	ID.AM (data inventories)
5	MFA and phishing training	MFA for every admin account and all remote access, as the Access Control Policy already	No MFA; the Friday attachment	PR.AA, PR.AT

		requires. Quarterly phishing simulations focused on invoice-style lures.		

Part 3. Tool Evidence

Result. Every zone allowed exactly the traffic in the design and blocked the rest; three faults found along the way were fixed and re-tested.

Method. A test script was run from one machine in each zone. It tried each allowed and each forbidden connection and recorded Open or Blocked. The pfSense firewall log was checked for the matching block entries. A game client tested UDP 7777 from the simulated Internet.

User zone:

```
Test                    Target            Expected Result  Verdict
----                    ------            -------- ------  -------
DC01 DNS                172.16.20.10:53   Allow    Open    PASS
DC01 Kerberos           172.16.20.10:88   Allow    Open    PASS
DC01 LDAP               172.16.20.10:389  Allow    Open    PASS
DC01 file shares (SMB)  172.16.20.10:445  Allow    Open    PASS
Log collector (WinRM)   172.16.30.10:5985 Allow    Open    PASS
DC01 RDP                172.16.20.10:3389 Deny     Blocked PASS
pfSense webGUI (User IP) 172.16.10.1:443  Deny     Blocked PASS
pfSense webGUI (Mgmt IP) 172.16.30.1:443  Deny     Blocked PASS
Mgmt workstation RDP    172.16.30.10:3389 Deny     Blocked PASS
DMZ game server SSH     172.16.40.10:22   Deny     Blocked PASS
```

Server zone:

```
Test                  Target            Expected Result  Verdict
----                  ------            -------- ------  -------
Log collector (WinRM) 172.16.30.10:5985 Allow    Open    PASS
Mgmt workstation RDP  172.16.30.10:3389 Deny     Blocked PASS
pfSense webGUI        172.16.20.1:443   Deny     Blocked PASS
User workstation SMB  172.16.10.100:445 Deny     Blocked PASS
DMZ game server SSH   172.16.40.10:22   Deny     Blocked PASS
Internet host SSH     203.0.113.50:22   Deny     Blocked PASS
```

Mgmt zone:

```
Test                    Target              Expected Result  Verdict
----                    ------              -------- ------  -------
DC01 RDP                172.16.20.10:3389   Allow    Open    PASS
DC01 file shares (SMB)  172.16.20.10:445    Allow    Open    PASS
DMZ game server SSH     172.16.40.10:22     Allow    Open    PASS
pfSense webGUI          172.16.30.1:443     Allow    Open    PASS
User workstation RDP    172.16.10.100:3389  Deny     Blocked PASS
User workstation SMB    172.16.10.100:445   Deny     Blocked PASS
Internet host SSH       203.0.113.50:22     Deny     Blocked PASS
```

DMZ zone:

```
TEST                    TARGET                EXPECTED RESULT     VERDICT
----                    ------                -------- ------     -------
DC01 file shares (SMB)  172.16.20.10:445/tcp  Deny     Timed out  PASS
DC01 DNS                172.16.20.10:53/tcp   Deny     Timed out  PASS
Log collector (WinRM)   172.16.30.10:5985/tcp Deny     Timed out  PASS
Mgmt workstation RDP    172.16.30.10:3389/tcp Deny     Timed out  PASS
User workstation SMB    172.16.10.100:445/tcp Deny     Timed out  PASS
pfSense webGUI          172.16.40.1:443/tcp   Deny     Timed out  PASS
Internet host SSH       203.0.113.50:22/tcp   Deny     Timed out  PASS
```

Simulated Internet:

```
acme-admin@player-01:~$ python3 /opt/acme-gameserver/acme_player.py 203.0.113.1 --seconds 2
join  : WELCOME b7d826b1
state : STATE 274016 1
pings : sent=4 lost=0 avg_rtt=1.6 ms
acme-admin@player-01:~$ for t in 203.0.113.1:22 203.0.113.1:80 203.0.113.1:443 203.0.113.1:445 203.0.113.1:3389 203.0.113.1:5985 172.16.40.10:22 172.16.20.10:44
5 172.16.30.10:3389; do timeout 3 bash -c "</dev/tcp/${t%:*}/${t#*:}" 2>/dev/null && echo "$t OPEN" || echo "$t blocked"; done
203.0.113.1:22 blocked
203.0.113.1:80 blocked
203.0.113.1:443 blocked
203.0.113.1:445 blocked
203.0.113.1:3389 blocked
203.0.113.1:5985 blocked
172.16.40.10:22 blocked
172.16.20.10:445 blocked
172.16.30.10:3389 blocked
```

The Internet box is cloned from the game server VM to save on space which is why it still contains “Acme” naming.

References

NIST (2024). The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29. Overview: nist.gov/cyberframework.

NIST (April 2025). SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile.

CISA, MS-ISAC, NSA and FBI (September 2023). #StopRansomware Guide.